

ANRH Publications

Audit de dette technique

10 juillet 2026

<https://pub.anrh.fr> (staging)

6 dettes CRITIQUES corrigées

Voir section 1 — Correctifs appliqués

1. Correctifs critiques appliqués

Les points suivants ont été corrigés le 10/07/2026. Ils ne nécessitent plus d'action immédiate.

#1 bin/reset-client-access.php

RÉSOLU

Problème : Mots de passe en dur dans le dépôt.

Action : Mots de passe générés via CLI/env — plus de secrets commités.

#2 tools/migrate-prestashop.php

RÉSOLU

Problème : Script migration accessible via HTTP.

Action : Exécution CLI uniquement (HTTP 403).

#3 inc/b2b/tools.php

RÉSOLU

Problème : Export CSV panier sans contrôle prix B2B.

Action : Export réservé aux clients connectés et approuvés.

#4 inc/b2b/tools.php

RÉSOLU

Problème : Compateur AJAX sans nonce.

Action : check_ajax_referer + nonce JS ajoutés.

#5 .github/workflows/

RÉSOLU

Problème : Déploiement sans validation préalable.

Action : Job valide (lint PHP, grep secrets) avant FTP.

#6 deploy-staging.yml

RÉSOLU

Problème : Déploiement non vérifié après envoi.

Action : Smoke test HTTP post-deploy + exclusion bin/tools du bundle.

2. Sécurité applicative (restant)

#1 inc/b2b/pricing.php

Élevé

Problème : Calcul prix HT sans gate centralisé.

Action : Ajouter anrhpucanviewprices() dans get_unit_price_ht pour les appels front.

#2 inc/b2b/client-pro.php

Élevé

Problème : Compte sans meta = approuvé par défaut.

Action : Statut pending par défaut pour les nouveaux comptes.

#3 inc/contact-form.php

Élevé

Problème : Formulaire devis sans rate limiting.

Action : Throttling IP + CAPTCHA.

#4 inc/newsletter.php

Élevé

Problème : Inscription AJAX sans limitation.

Action : Rate limit par IP/email.

#5 inc/b2b/quotes.php

Moyen

Problème : PDF devis : capability edit_posts trop large.

Action : Restreindre aux rôles dédiés.

#6 inc/gdpr.php

Moyen

Problème : Bandeau cookies sans blocage scripts.

Action : Intégrer un CMP.

3. Qualité de code et architecture

#7 Thème entier

Élevé

Problème : Aucun test automatisé.

Action : PHPUnit sur auth B2B, panier, devis.

#8 assets/js/main.js

Élevé

Problème : Monolithe 2700+ lignes.

Action : Découper + build Vite.

#9 functions.php

Élevé

Problème : 10+ CSS sur toutes les pages.

Action : Enqueue conditionnel par template.

#10 inc/catalogue-search.php

Élevé

Problème : Requêtes illimitées par recherche.

Action : Pagination / index.

#11 inc/product-colors.php

Moyen

Problème : God-module 1200+ lignes.

Action : Scinder en modules.

#12 inc/demo-data.php

Moyen

Problème : Données démo au switch thème.

Action : Désactiver en production.

4. Déploiement et infrastructure

#13 FTP OVH

Élevé

Problème : Protocole FTP en clair, déploiement non atomique.

Action : SFTP si disponible ; healthcheck (fait).

#14 deploy-staging.yml

Élevé

Problème : Fichiers orphelins non supprimés sur le serveur.

Action : Sync miroir ou nettoyage ciblé.

#15 staging-health.php

Moyen

Problème : Script diagnostic en webroot.

Action : Retirer après validation.

#16 export-staging-db.ps1

Moyen

Problème : Export DB manuel Windows uniquement.

Action : wp-cli search-replace cross-platform.

#17 README.md

Faible

Problème : Documentation partiellement obsolète.

Action : Aligner sur WP 7.0 et scope deploy.

5. Configuration et WordPress core

#18 wp-config.template.php

Élevé

Problème : Sels WordPress statiques dans le repo.

Action : Sels uniques par environnement via secrets.

#19 .gitignore

Élevé

Problème : WordPress core versionné (~5500 fichiers).

Action : Déployer le core via Composer/wp-cli.

#20 wp-config.template.php

Moyen

Problème : Pas de DISALLOW_FILE_EDIT, FORCE_SSL_ADMIN.

Action : Durcissement production.

#21 plugins/

Faible

Problème : Akismet inutile, UpdraftPlus lourd.

Action : Nettoyer les plugins.

6. Plan de remédiation

P1 — Important

- Sels WordPress uniques par environnement
- Export DB avec wp search-replace (serialized-safe)
- Rate limiting sur les formulaires publics
- Tests B2B minimaux en CI

P2 — Amélioration

- Découper main.js et product-colors.php
- CSS/JS conditionnels par page
- Retirer staging-health du deploy automatique
- Réduire le scope git (core WP hors repo)

P3 — Confort

- Audit accessibilité WCAG 2.1 AA
- Internationalisation complète (.pot)
- Stratégie production documentée